PHISHING ANALYSIS & AWARENESS CAMPAIGN

Cyber Security Project 02 · Beginner Level

Prepared by	Muhammad Ali Kashif
Assessment date	6 October 2026
Scope	Five public-repository phishing samples; technical and human-factor analysis
Classification	Educational · Sanitized · Defensive analysis only

Safety statement

No suspicious link or attachment was opened. URLs are defanged or described by domain only. Authentication and routing findings are taken from preserved headers or cited public analyses. Current threat-intelligence results are not presented as historical facts.

Submission target: The Sky Gen · TSG/CS/P02/2026

01 Executive Summary

This report examines five phishing emails chosen from public research repositories. Together they demonstrate display-name impersonation, domain mismatch, account-security lures, credential harvesting, reply diversion, URL shortening, tracking pixels, advance-fee fraud and abuse of apparently authenticated infrastructure.

Overall result: all five samples are phishing or malicious spam. Authentication failures strengthened four verdicts; one case demonstrates that even passing SPF/DKIM does not make a message trustworthy.

Methodology and safe handling

• Preserve the original message and inspect raw source rather than rendering active content.

• Compare display name, From, Reply-To, Return-Path and the earliest untrusted Received hop.

• Read the receiver-stamped Authentication-Results for SPF, DKIM and DMARC.

• Extract link destinations from source or hover/preview; never open the destination directly.

• Compare claimed brand with sender domain, destination domain and domain-age evidence.

• Identify urgency, fear, authority, reward, scarcity and curiosity tactics.

• Reach a verdict from the combined evidence, not from one signal alone.

SPF, DKIM and DMARC in plain language

SPF	Checks whether the sending server is authorized to send for the envelope domain.
DKIM	Checks a cryptographic signature to detect unauthorized alteration and identify the signing domain.
DMARC	Checks whether SPF or DKIM passes and aligns with the visible From domain, then applies the domain owner’s policy.
Important limitation	A phisher can pass all three when using an attacker-owned or compromised legitimate service. Content and context still matter.

Risk scale

Critical: credential/payment theft or strong impersonation with actionable lure. **High:** multiple independent phishing indicators. **Medium:** malicious or deceptive promotion with lower immediate impact.

Sample 1: Microsoft unusual-sign-in impersonation

Public honeypot sample: phishing_pot sample-10.eml

Source	rf-peixoto/phishing_pot; corroborated by public header analysis
Claimed identity	Microsoft account team
Actual sender / route	no-reply@access-accsecurity[.]com; Reply-To: sotrecognizd@gmail[.]com; origin 89[.]144[.]44[.]2
Primary objective	Start a fraudulent conversation and/or obtain account information.
Risk verdict	**HIGH — confirmed phishing indicators**

Header authentication

SPF	DKIM	DMARC
none	none	permerror

What the authentication results mean

SPF and DKIM provided no authenticated identity. DMARC could not produce a valid aligned result. This does not alone prove phishing, but it strongly supports the other evidence.

Sender and lookalike analysis

The display name invokes Microsoft, while the visible From domain is access-accsecurity[.]com, the envelope domain is thcultarfdes[.]co[.]uk, and replies go to a Gmail address. None is a Microsoft-controlled identity.

Domain-age assessment

Historical WHOIS evidence records access-accsecurity[.]com as created on 2 July 2023. The sample was delivered on 8 September 2023, making it approximately 68 days old at delivery—an unusually young domain for a supposed Microsoft security service.

Safe URL inspection

The visible buttons resolved to mailto actions directed to the same Gmail collection address; a 1×1 tracking image referenced thebandalisty[.]com. These were inspected as source strings, not opened.

Social-engineering breakdown

• Authority: the “Microsoft account team” display name borrows brand trust.

• Fear: an unusual sign-in warning implies account compromise.

• Urgency: the user is pushed to report or respond immediately.

• Generic addressing and irrelevant word-salad padding indicate bulk delivery and filter evasion.

Analyst conclusion

The message is a high-confidence phishing attempt: brand impersonation, three-domain misalignment, missing authentication, generic greeting and fear-based account language reinforce one another.

Sample 2: Binance verification lure

Public honeypot sample: phishing_pot sample-12.eml

Source	rf-peixoto/phishing_pot; public analysis of samples 10 and 12
Claimed identity	Binance
Actual sender / route	Claimed From: ses.binance[.]com; sending/hosting route: ilonasavola[.]com via wp-cloud[.]fi
Primary objective	Drive the victim to an unrelated credential-harvesting destination.
Risk verdict	**CRITICAL — credential-harvesting link**

Header authentication

SPF	DKIM	DMARC
not aligned with Binance	not aligned with Binance	fail for the claimed From identity

What the authentication results mean

The receiver's DMARC evaluation failed the brand identity. An "auth=pass" record for a hosting relay only indicates the relay authenticated its own customer; it does not prove Binance sent the email.

Sender and lookalike analysis

The visible identity references Binance, but the route used ilonasavola[.]com/wp-cloud[.]fi infrastructure and the action link used zzdzw[.]com. Authentication for attacker-controlled infrastructure does not establish Binance legitimacy.

Domain-age assessment

A cited VirusTotal record first saw the URL on 13 July 2022, roughly 40 days before the 22 August 2022 email, and labeled it newly registered. First-seen is not the same as WHOIS creation, so it is treated as supporting—not definitive—age evidence.

Safe URL inspection

Source inspection found a single destination at zzdzw[.]com. A cited VirusTotal snapshot reported 2/92 detections and "Newly Registered." No live visit was performed; the domain is retained only in defanged form.

Social-engineering breakdown

• Authority: trusted cryptocurrency-exchange branding.

• Fear and loss: account or withdrawal restrictions are threatened.

• Deadline pressure: a 72-hour verification window discourages careful checking.

• Single-action design funnels the victim directly to the credential site.

Analyst conclusion

This is a critical credential lure. A brand claim, time pressure, unrelated destination and threat of account restrictions make the intent clear even without relying solely on authentication.

Sample 3: Fake Microsoft account-lock notice

Public Gmail-captured sample: sample2.eml

Source	jacobdcook/Phishing-Analysis-Lab, samples/sample2.eml
Claimed identity	Microsoft / Microsoft 365
Actual sender / route	noreply@microsoftonline-verify[.]com; origin 178[.]238[.]225[.]91 (Contabo VPS)
Primary objective	Steal credentials through an account-verification page.
Risk verdict	**CRITICAL — credential phishing**

Header authentication

SPF	DKIM	DMARC
fail	fail	fail

What the authentication results mean

The sending IP was not authorized for the claimed domain, no valid DKIM signature was verified, and DMARC alignment failed. These receiver-stamped results materially support spoofing/deception.

Sender and lookalike analysis

The actual sender is noreply@microsoftonline-verify[.]com. The domain adds “verify” to a Microsoft-like string but is not Microsoft’s login.microsoftonline.com domain. The origin was a Contabo VPS, not Microsoft mail infrastructure.

Domain-age assessment

A reliable historical creation date was not available in the preserved evidence. The absence of age data is recorded rather than guessed. The decisive issue is ownership: microsoftonline-verify[.]com is distinct from Microsoft’s established microsoftonline.com domain.

Safe URL inspection

The preserved sample contains an HTML action link. The destination is described as an account-verification lure and is not reproduced as a clickable URL. Review was limited to raw source.

Social-engineering breakdown

• Fear: the account is described as locked or at risk.

• Urgency: immediate verification is requested.

• Authority: Microsoft branding and security vocabulary create false legitimacy.

• Lookalike wording exploits users who scan the beginning of a domain rather than its registrable ending.

Analyst conclusion

A lookalike domain, failed authentication and account-lock language form a consistent credential-phishing pattern.

Sample 4: OneCasino promotional lure

Real spam captured from Gmail: sample1.eml

Source	jacobdcook/Phishing-Analysis-Lab, samples/sample1.eml
Claimed identity	OneCasino
Actual sender / route	132784@534617.vav.proo55.us[.]com; Return-Path bounce@vav.proo55.us[.]com; origin 141[.]95[.]0[.]46
Primary objective	Drive clicks through a shortened URL to a suspicious promotional/phishing destination.
Risk verdict	**HIGH — deceptive campaign / phishing**

Header authentication

SPF	DKIM	DMARC
pass for attacker domain	pass for attacker subdomain	not evidence of brand alignment

What the authentication results mean

SPF/DKIM pass means the infrastructure was authorized to send for its own domain. It does not prove that OneCasino authorized the email. Brand-to-domain mismatch remains the key finding.

Sender and lookalike analysis

The sender used a random-looking address at 534617.vav.proo55.us[.]com and an OVH VPS. Passing authentication applied only to the attacker-controlled subdomain, not to the casino brand being presented.

Domain-age assessment

The sending identity is a nested subdomain of us[.]com, so it does not have an independent WHOIS creation date. Parent-domain age would not establish the age or legitimacy of the attacker-created subdomain; this is explicitly marked “not independently measurable.”

Safe URL inspection

“Start Spinning Now,” “Unsubscribe,” and “Terms” all resolved to the same TinyURL. A cited VirusTotal snapshot recorded 2/94 detections. The repeated destination and shortener concealment are stronger signals than the numerical score alone.

Social-engineering breakdown

• Reward/scarcity: a gambling promotion promises immediate benefit.

• Curiosity: the user is encouraged to reveal the offer through a click.

• False compliance cues: unsubscribe and terms links mimic a legitimate campaign.

• Automation: Auto-Submitted headers and randomized sender structure indicate bulk operation.

Analyst conclusion

The campaign is malicious/deceptive spam with phishing characteristics: brand mismatch, URL shortening, identical CTA/unsubscribe destinations and bulk-mail automation.

Sample 5: Post Fiji advance-fee fraud

Real public-repository sample analyzed as advance-fee fraud

Source	phishing_pot-derived case; public analysis by UmerAkhter10
Claimed identity	Post Fiji / prize authority
Actual sender / route	Spoofed nemani.tukunia@postfiji[.]com[.]fj; Reply-To mywoodforestbiz[.]7@gmail[.]com; origin 109[.]202[.]24[.]52
Primary objective	Initiate contact, collect personal information and progress the victim toward an advance payment.
Risk verdict	**HIGH — advance-fee fraud**

Header authentication

SPF	DKIM	DMARC
fail	none	none / no usable policy

What the authentication results mean

The origin IP was not authorized for the claimed domain, the email had no valid DKIM signature, and no usable DMARC protection established aligned identity.

Sender and lookalike analysis

The message claimed postfiji.com[.]fj but originated from 109[.]202[.]24[.]52 through a Russian government-named relay. Replies were diverted to mywoodforestbiz[.]7@gmail[.]com. The From and To values were also made identical to confuse the recipient.

Domain-age assessment

Reliable historical registration data for the .com.fj identity was not available in the preserved evidence. Because the legitimate-looking domain was spoofed, even an old domain would not validate this message; SPF failure proves the observed sender was unauthorized.

Safe URL inspection

The attack relied primarily on reply diversion rather than a verified web link. The correct safe response is to avoid replying and independently contact the real organization using a known official channel.

Social-engineering breakdown

• Authority: postal/official identity implies legitimacy.

• Reward: a valuable benefit is promised.

• Urgency: the recipient is encouraged to respond before reconsidering.

• Commitment escalation: the first reply opens a path toward identity collection and advance-fee demands.

Analyst conclusion

This is high-confidence advance-fee fraud. Spoofing, reply diversion, missing authentication and reward language point toward a staged payment scam.

02 Red Flag Comparison Table

Signal	S1 Microsoft	S2 Binance	S3 MS lock	S4 OneCasino	S5 Post Fiji
Display/brand mismatch	Yes	Yes	Yes	Yes	Yes
Reply-To / route mismatch	Yes	Yes	Not stated	Yes	Yes
Lookalike/unrelated domain	Yes	Yes	Yes	Yes	Spoofed
SPF	None	Not aligned	Fail	Pass*	Fail
DKIM	None	Not aligned	Fail	Pass*	None
DMARC	Permerror	Fail	Fail	Not brand proof	None
URL concealment	Mailto + pixel	Unrelated domain	HTML lure	Shortener	Reply-based
Main tactic	Fear/authority	Fear/deadline	Fear/urgency	Reward/curiosity	Reward/authority
Risk	High	Critical	Critical	High	High

*Pass means the attacker or sending platform authenticated its own domain. It does not validate the impersonated brand.

Cross-sample findings

• All five use a trusted identity or familiar service to reduce suspicion.

• Four show failed, absent or misaligned authentication; one demonstrates that authentication can pass for attacker-controlled infrastructure.

• Three drive a web action, while two use reply-based social engineering.

• Urgency and authority are the most repeated human-pressure techniques.

• Domain ownership and alignment are more meaningful than whether a message merely contains professional branding.

Most useful employee rule

Pause, inspect the complete sender address and destination, then verify through an independent official channel. Do not use the contact details supplied by the suspicious message.

03 Awareness Campaign and Response Procedure

Campaign objective

Reduce successful phishing interactions by teaching a short repeatable behavior: **STOP — Sender, Tactic, Objective, Prove.** The attached A3 poster is designed for distance reading, while the one-page guide supplies the reporting workflow.

Employee reporting workflow

• Do not click, reply, scan a QR code, download an attachment or call a number supplied in the message.

• Use the organization's "Report phishing" button or forward as an attachment to the approved security mailbox.

• Include the original message/header when policy allows; do not paste live links into chat.

• If interaction occurred, disconnect only if instructed, contact IT/security immediately, change the affected password from a known-clean route and report any submitted data.

• Delete the message only after reporting, so the security team can preserve evidence.

Technical recommendations

Email gateway	Enforce DMARC-aligned identity where appropriate; flag external display-name impersonation and Reply-To mismatch.
Web controls	Use URL rewriting/sandboxing, block newly registered or confirmed malicious domains and monitor click telemetry.
Identity	Require phishing-resistant MFA where possible; monitor impossible travel, unusual sign-ins and mass mailbox rules.
Awareness	Run short scenario-based training and measure reporting rate, click rate and time-to-report.
SOC response	Search for matching senders, subjects, hashes and URLs; purge related mail; identify clicks; reset exposed credentials; document IOCs.

Limitations

This is a static educational assessment. Threat-intelligence scores change over time, public samples may be partially redacted, and historical WHOIS is not available for every domain. Missing evidence is stated explicitly rather than inferred. A clean reputation result never overrides contradictory header and behavioral evidence.

04 Evidence Register and References

Evidence register

E-01	phishing_pot sample-10.eml — Microsoft unusual-sign-in impersonation.
E-02	phishing_pot sample-12.eml — Binance verification lure.
E-03	jacobdcook/Phishing-Analysis-Lab sample2.eml — Microsoft account-lock lure.
E-04	jacobdcook/Phishing-Analysis-Lab sample1.eml — OneCasino promotional lure.
E-05	phishing_pot-derived Post Fiji sample — advance-fee fraud analysis.

References

1. The Sky Gen, Cyber Security Project 02 Beginner Brief, TSG/CS/P02/2026.

2. rf-peixoto/phishing_pot, public honeypot phishing corpus: https://github.com/rf-peixoto/phishing_pot

3. UscTrojansDodgers56, sample-10 and sample-12 analysis: https://github.com/UscTrojansDodgers56/phishing-email-analysis

4. jacobdcook, Phishing Analysis Lab and preserved samples: https://github.com/jacobdcook/Phishing-Analysis-Lab

5. UmerAkhter10, Post Fiji advance-fee analysis: https://github.com/UmerAkhter10/Phishing-Email-Analysis

6. Scam Detector, historical registration details for access-accsecurity.com: https://www.scam-detector.com/validator/access-accsecurity-com-review/

7. MITRE ATT&CK;, Phishing T1566: https://attack.mitre.org/techniques/T1566/

8. CISA, Recognize and Report Phishing: https://www.cisa.gov/secure-our-world/recognize-and-report-phishing

9. DMARC.org, SPF/DKIM/DMARC overview: https://dmarc.org/overview/

Authorship and ethics statement

Prepared for defensive education. No phishing email was sent, no credential was collected, no live malicious link was opened, and no personal mailbox identifier is included. The author must be able to explain the workflow, evidence, limitations and conclusions during review.

Prepared by	Muhammad Ali Kashif
Date	6 October 2026
Status	Final submission copy